

MailTrace

Complete product explanation and testing guide

SIH26106 - Explainable email threat detection with origin and campaign forensics

Upload a saved email. See the evidence behind its risk, probable hosting infrastructure and campaign relationships.

This document describes the current working prototype, the exact demo flow, the eight crafted samples, test commands, API routes and the boundaries that must be stated honestly.

Current verified state: 5 automated tests passing; live API health 200; eight sample analyses; campaign graph 2 nodes / 1 edge; PDF export working.

1. What MailTrace is

MailTrace is a local-first email analyst lab. It is designed for an investigator or helpdesk analyst who has received a suspicious saved .eml file and needs more than a simple spam/not-spam answer.

```
.eml file
-> exact-byte hash
-> MIME/header/body parsing
-> authentication evidence
-> sender alignment checks
-> Received-hop analysis
-> offline domain and IP context
-> explainable score and label
-> local case storage
-> campaign correlation
-> forensic PDF
```

The core value is explainability. The analyst can see which fields caused the warning, what infrastructure appears in the headers, which other messages share indicators and what evidence fingerprint belongs to the uploaded file.

It is not a Gmail replacement, a mail gateway, an antivirus sandbox or a tool that claims to locate a human attacker.

2. End-to-end data flow

Stage	What happens	Output
Capture	The exact uploaded .eml bytes are read locally.	SHA-256, byte size, filename
Extract	Python email MIME parser reads headers, text/plain body, URLs and attachments.	Structured parsed email
Explain	Authentication results, alignment, domain age, content cues and origin context are combined.	Reasons, score, label
Connect	Stored cases are compared for shared domains, Reply-To values and origin IPs.	Campaign graph
Report	The case is rendered as a one-page A4 PDF.	Portable evidence summary

3. What each code component does

File	Responsibility
app.py	FastAPI routes, orchestration, uploads, sample analysis, case retrieval, graph and PDF endpoints.
mailtrace/parse.py	Parses email fields, authentication evidence, URLs, Received hops, origin and hashes.
mailtrace/score.py	Transparent weighted score and CLEAN/SPOOF/PHISH/BEC label.
mailtrace/intel.py	Reads offline domain intelligence from data/whois_cache.json.
mailtrace/graph_store.py	Builds the NetworkX undirected graph from shared indicators.
mailtrace/store.py	Persists parsed case JSON, score and hash in SQLite.
mailtrace/pdf_report.py	Creates the one-page forensic case PDF.
ui/index.html	Upload/sample screen, case view, reasons, map, graph, hash footer and PDF button.
scripts/write_samples.py	Regenerates the eight safe, local crafted .eml files.
tests/test_pipeline.py	Parser, scoring, complete corpus, graph, PDF and attachment-hash tests.

4. Email parsing and evidence

MailTrace uses Python's standard email parser. It does not execute the message or treat the email body as a program.

- From display name, address and domain
- Reply-To and Return-Path values and their domains
- Subject and Message-ID
- Plain-text body, limited to the first 4,000 characters
- URLs found in the body or From field, deduplicated to 20
- Received headers and extracted IPv4 addresses
- Authentication-Results, Received-SPF and ARC authentication evidence
- Attachment filename, MIME type, size and SHA-256 metadata, limited to 20

Attachments are metadata-only in this build: MailTrace hashes them but does not open, execute or detonate them. The main UI and current PDF focus on the header, hop, scoring and campaign evidence.

5. Sender and authentication checks

MailTrace compares the visible identity with the delivery identity. A message may display an official name while using a Gmail address, a different Reply-To domain or a different Return-Path domain.

- Gmail display-name heuristic: a Gmail address wearing a longer official-looking display title is flagged.
- Reply-To mismatch: the domain receiving the reply differs from the visible From domain.
- Return-Path mismatch: the bounce/delivery domain differs from the visible From domain.
- SPF, DKIM and DMARC are displayed as pass, fail, none or unknown when those results appear in the headers.

Important: the demo reads authentication results already written in the .eml. It does not yet perform live DNS lookup or independent cryptographic DKIM verification. In production, trusted receiving infrastructure should perform those checks.

6. Received hops and probable origin

MailTrace reads each Received header, extracts public IPv4 addresses, ignores common local addresses and uses the last public hop in normal header order as the earliest reliable public hop.

The demo uses a small offline IP table so the same sample always produces the same result:

IP	Demo context
103.25.60.12	Chandigarh / campus-like organisation
18.184.10.20	Frankfurt / AWS / cloud
52.94.76.10	Dublin / AWS / cloud
8.8.8.8	Unknown / public DNS
185.199.108.153	Unknown / Fastly CDN

Correct wording: 'The earliest reliable public hop appears to be hosted in Frankfurt by AWS.'
Incorrect wording: 'The attacker is in Frankfurt.' IP geolocation describes network infrastructure, not a person's GPS location.

7. Offline domain intelligence

The current domain cache is data/whois_cache.json. It contains reproducible demo facts such as approximate age, registrar label and a note. No live WHOIS request is made during the demonstration.

- pec.edu.in: established college domain
- gmail.com: consumer mailbox
- paypa1.com: lookalike and four days old in the demo cache
- pec-edu.in: lookalike of pec.edu.in and six days old
- mail-secure.net: young throwaway-style domain and twelve days old

A cached domain younger than 30 days contributes a young-domain signal. A young domain is suspicious context, not proof of criminality.

8. Explainable risk scoring

The score starts at 8 and adds fixed points for observed signals. It is clamped to 0-100. It is a risk indicator, not a calibrated probability and not an accuracy percentage.

Signal	Points
Gmail address wearing official-looking title	+28
Reply-To domain mismatch	+18
Return-Path domain mismatch	+10
SPF failure	+22
DKIM failure	+12
DMARC failure	+12
Lookalike domain	+20
Young cached domain	+14
Cloud-origin hop	+10
Password/login language	+16
Invoice/payment redirect language	+18
Urgency language	+8

The UI prints up to six strongest reasons. A signal can contribute to the score even when the reason list has reached that display limit.

9. Labels

- CLEAN: low score and no major spoof/phishing cue.
- SPOOF: sender alignment or authentication problem.
- PHISH: high score involving a lookalike domain or password/login lure.
- BEC: payment, invoice or account-change pattern. The BEC rule is checked before the broader spoof rule.

10. Campaign graph

NetworkX creates one node per analyzed filename. Two cases are connected when they share a meaningful indicator:

- sender, Reply-To or Return-Path domain
- full Reply-To address
- probable origin IP

07 cloud hops ---- Reply-To + same hop + domain ---- 08 campaign twin

The visible graph is currently a custom inline SVG because raw network canvases were too dense for slide and projector viewing. The graph caption deliberately says: shared indicators, not identity proof.

11. Local storage

Cases are saved in data/mailtrace.db. The database contains the case ID, filename, SHA-256, parsed JSON payload and creation time. It persists across server restarts.

Restarting the server does not clear old cases. Use the reset endpoint before a clean campaign demonstration:

```
curl -X POST http://127.0.0.1:8777/api/reset
```

12. Forensic PDF

The case PDF is a one-page A4 summary containing the case ID, score, label, sender, Reply-To, reasons, origin hop, up to eight Received hops, campaign links, exact-file SHA-256 and the hosting-not-GPS disclaimer.

It is a portable case summary, not a replacement for preserving the original email file. The report is generated from the stored parsed case.

13. The teammate ML files

The teammate model_A.pkl and tfidf_vectorizer.pkl are not loaded by the current application. They are a traditional TF-IDF plus logistic-regression body classifier for ham/spam language. They cannot by themselves trace Received hops, inspect sender alignment, validate authentication or correlate campaigns.

They can be added later as an optional body-language signal, but the forensic parser, authentication evidence, origin context, graph and report are the main SIH26106 product.

14. Eight demo samples and expected results

Sample	Expected	What it demonstrates
01_clean.eml	CLEAN / 8	Aligned college sender, all auth pass, Chandigarh campus-like hop.
02_display_spoof.eml	SPOOF / 100	Official-looking display name on Gmail, mismatched Reply-To and auth failures.
03_lookalike.eml	PHISH / 98	paypa1 lookalike, failed auth, young domain and Dublin cloud hop.
04_spf_fail.eml	SPOOF / 64	Claimed college sender but SPF, DKIM and DMARC fail; Frankfurt AWS hop.
05_bec_invoice.eml	BEC / 100	Urgent payment/account-change pattern with mismatched reply path.
06_cred_phish.eml	PHISH / 100	Mailbox suspension/login lure, lookalike domain and failed auth.
07_cloud_hops.eml	SPOOF / 66	Three Received hops and probable Frankfurt AWS origin.
08_campaign_twin.eml	SPOOF / 66	Second email sharing Reply-To, domain and origin IP with sample 07.

15. How to start it

```
cd /root/sih-mailtrace
```

```
# easiest path
bash run.sh
```

```
# or manually
python3 scripts/write_samples.py
python3 -m pytest -q
python3 -m uvicorn app:app --host 127.0.0.1 --port 8777
```

Open <http://127.0.0.1:8777>. The run script installs requirements, regenerates samples, runs tests and starts Uvicorn on localhost port 8777.

16. Best click-by-click test

1. Reset old cases with the curl command above.
2. Open the local URL and click 04_spf_fail.eml.
3. Verify SPOOF, score 64, SPF/DKIM/DMARC failures, Frankfurt/AWS origin, hop list and map.
4. Click 07_cloud_hops.eml and inspect the three Received hops.
5. Click 08_campaign_twin.eml and verify the two-node graph and one relationship caption.
6. Click Download case PDF and verify the case ID, reasons, origin, campaign link and SHA-256.
7. Finally reset again if the next person needs a clean demo.

17. API test checklist

Action	Command or route	Expected
Health	GET /api/health	200 and product MailTrace
Samples	GET /api/samples	Eight .eml files
Reset	POST /api/reset	cleared: true
Sample analysis	POST /api/analyze-sample/04_spf_fail.eml	SPOOF / 64
Raw upload	POST /api/analyze with multipart file	Case JSON and ID
Stored cases	GET /api/cases	IDs, filenames and scores
Graph	GET /api/graph	nodes and shared-indicator edges
Case	GET /api/case/{id}	Full parsed case JSON
PDF	GET /api/case/{id}/pdf	application/pdf
Bad sample	POST unknown sample	404
Empty upload	POST empty file	400

Useful direct commands:

```
curl http://127.0.0.1:8777/api/health
curl http://127.0.0.1:8777/api/samples
curl -X POST http://127.0.0.1:8777/api/analyze-sample/04_spf_fail.eml
curl -F "file=@samples/05_bec_invoice.eml" http://127.0.0.1:8777/api/analyze
python3 -m pytest -q
```

18. Current verified result

- Automated suite: 5 passed.
- Live health: HTTP 200 with product MailTrace and problem statement SIH26106.
- All eight sample endpoints analyzed successfully.
- Campaign test: 2 nodes, 1 edge, caption Reply-To + same hop + domain.
- PDF endpoint: HTTP 200, application/pdf.
- Attachment test: metadata and SHA-256 verified without execution.

19. Boundaries and future production work

- No Gmail or Outlook ingestion in the SIH demo.
- No live DNS-based SPF/DKIM/DMARC verification yet.
- No live WHOIS or global reputation service.
- Offline demo IP data is not a full GeoIP/ASN database.
- No malware detonation or antivirus engine.
- No exact attacker location or person attribution.
- No automatic quarantine, blocking or SOC alert integration.
- The score is rule fusion, not a calibrated probability.
- The local server binds to 127.0.0.1 and has no production authentication layer.

20. One-minute handoff for the team

Use this short explanation when a teammate or judge asks what MailTrace actually does:

1. We upload a saved .eml file instead of connecting to a live mailbox.
2. MailTrace preserves an exact SHA-256 fingerprint and parses the sender, Reply-To, Return-Path, authentication evidence, body, URLs, attachments and Received hops.
3. It explains the risk with visible reasons, estimates the hosting infrastructure behind the earliest reliable public hop and shows the hop path.
4. When multiple emails share a Reply-To, domain or origin IP, it creates a campaign lead. That is correlation, not proof of identity.
5. It stores the case locally and exports a portable forensic PDF containing the evidence summary and file fingerprint.

Say this exactly:

MailTrace turns a suspicious saved email into an explainable case file. It tells us what the message claims, what the headers reveal, where the infrastructure appears to be hosted, which other messages share indicators and what evidence should be preserved.

Never say: 'we found the hacker' or 'the IP proves the attacker's location.'